

## Narrativa explicativa – GQM + PRAGMATIC aplicado a indicadores NIST CSF 2.0

### 1. Del objetivo nacional al log de sistema

Uno de los problemas clásicos de la ciberseguridad es la fractura entre los grandes enunciados estratégicos (“reforzar la resiliencia del país”) y los datos prosaicos que salen de un SIEM o de un sistema de gestión de identidades.[web:46] La metodología GQM se diseñó precisamente para tender ese puente: se parte del **Goal** (el “para qué”), se desciende a las **Questions** (qué necesitamos saber) y solo al final se eligen las **Metrics** (qué medimos exactamente).[web:35][web:36][web:41]

Cuando se combina con NIST CSF 2.0, esto significa que no hablamos de métricas en abstracto, sino de métricas que sirven a funciones concretas (Govern, Identify, Protect, Detect, Respond, Recover) y a objetivos nacionales de resiliencia, continuidad y seguridad digital.[web:5][web:22]

### 2. La segunda criba: PRAGMATIC

GQM nos ayuda a evitar la colección caótica de números sin propósito. Pero, incluso con GQM, podemos acabar con métricas que son bonitas en papel y poco útiles en la práctica. Ahí entra PRAGMATIC: un conjunto de nueve criterios que permiten juzgar la calidad de cada métrica y compararlas entre sí.[web:40][web:44][web:47]

La idea es sencilla y poderosa: una métrica que no predice nada, no está alineada con los objetivos, no lleva a ninguna acción, es fácil de manipular, incomprensible, imprecisa, lenta, dependiente de opiniones o carísima de obtener... quizá no merezca estar en el cuadro de mando. En cambio, una métrica que puntúa alto en la mayoría de criterios es candidata a quedarse.

### 3. Métricas con propósito, no colecciones numéricas

Tomemos como ejemplo la cobertura de MFA en cuentas de alto riesgo. El objetivo no es “tener MFA porque lo dice el manual”, sino **reducir la probabilidad de compromiso de credenciales privilegiadas**. [web:5] Las preguntas derivadas (¿qué porcentaje de cuentas críticas tiene MFA?, ¿está mejorando esa cifra?) conectan directamente con decisiones de inversión, de priorización y de gestión de excepciones.[web:35][web:39]

Al pasar estas métricas por el filtro PRAGMATIC vemos que son, en general, bastante predictivas, muy relevantes y extremadamente accionables.[web:40][web:44][web:47] Se entienden bien, se pueden automatizar en buena medida y su coste es razonable. En otras palabras: merecen un sitio estable en el tablero de mandos.

### 4. Evitar métricas tóxicas o inútiles

No todas las métricas que se usan hoy en día superarían con buena nota la criba PRAGMATIC.[web:44][web:47] Algunas son casi decorativas (“número de firewalls instalados”), otras fomentan comportamientos perversos (“número de incidentes reportados”, si se penaliza al que reporta) y otras

son tan costosas de obtener que nadie las actualiza. El resultado es previsible: cuadros de mando que envejecen mal y que la dirección deja de mirar.

El enfoque propuesto invita a hacer algo saludable: poner todas las métricas sobre la mesa, puntuarlas honestamente según PRAGMATIC y **jubilarse** sin remordimientos aquellas que no aportan valor. No pasa nada por tener menos métricas, siempre que sean mejores y estén claramente vinculadas a objetivos.

## 5. Trazabilidad: del Consejo al operador del SOC

El gran valor añadido de combinar GQM con PRAGMATIC y NIST CSF 2.0 es la trazabilidad.[web:46] Se puede recorrer el camino en ambos sentidos:

- Desde el Consejo: “queremos reducir el tiempo de recuperación de servicios críticos” → función RECOVER → preguntas sobre RTO/RPO → métricas sobre cumplimiento en ejercicios y en incidentes reales.[web:5]
- Desde el SOC: “hemos reducido el MTTR en 6 horas” → métrica DE → pregunta sobre capacidad de detección → objetivo de limitar el impacto de incidentes graves → contribución medible a la resiliencia de la organización.[web:22]

Esta trazabilidad depura discusiones y alinea mejor a técnicos, gestores y reguladores.

## 6. Nivel nacional: una orquesta de métricas

Cuando el foco es un país (o un sector entero), el reto se amplifica. No basta con que cada organización tenga sus métricas; hay que armonizarlas para que, al agregarlas, tenga sentido hablar de “resiliencia nacional” o “madurez sectorial”. [web:22] NIST CSF 2.0 proporciona un vocabulario común, GQM marca la lógica de descenso desde los objetivos nacionales, y PRAGMATIC ayuda a seleccionar un subconjunto de métricas que funcionen bien en entornos muy distintos.[web:5][web:40][web:47]

El resultado deseable no es una sinfonía de 500 indicadores incomprensibles, sino una partitura manejable de métricas robustas que digan cosas importantes con números sencillos.

## 7. De la teoría a la hoja de cálculo

El marco integrativo se plasma finalmente en dos artefactos muy poco glamorosos, pero esenciales:

- Un cuestionario que recoge, de forma estructurada, el estado de los procesos y capacidades asociados a cada función CSF.
- Una hoja de cálculo que asigna valores, agrupa por funciones, calcula índices de madurez y proyecta, cuando es posible, el ROI de las inversiones.[web:46]

La gracia está en que, gracias a GQM, cada número tiene una historia detrás; y gracias a PRAGMATIC, se han quedado solo los números que aportan algo a la historia que nos importa.

## 8. Un uso prudente, pero ambicioso

Ni GQM ni PRAGMATIC son varitas mágicas, pero ayudan a tomar en serio las métricas de ciberseguridad.[web:40][web:44][web:47] Aplicados con criterio, evitan tanto el fetichismo numérico

como la alergia a medir. Y sobre todo, enfocan la conversación en lo que realmente importa: **cómo saber, con la mejor evidencia posible, si estamos gestionando el riesgo ciber de forma responsable y eficaz.**

En ese sentido, el marco no pretende dictar qué métricas “hay que tener”, sino ofrecer una forma coherente de pensar, diseñar y depurar las métricas que cada organización —y cada país— decida usar.